

SIMATS ENGINEERING ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking COURSE CODE: ITA1407

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01 Total Marks:100

Annexure A SECURITY TESTING SIMULATION TASK

Code of Conduct:

*I (Lavanya K / 192565025) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action. **Signature of the student:***

S.No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Tool Selection and Configuration(20)	Selects appropriate open source tools, configures them correctly, and clearly explains the purpose of each tool.	Selects suitable tools and configures them with minor errors or limited explanation.	Uses basic tools with partial configuration and limited understanding.	Selects inappropriate tools or fails to configure them correctly.	
2	Testing Procedure and Execution(20)	Follows a systematic, authorized, safe, and well documented testing procedure within the approved scope.	Performs the major testing steps correctly with minor omissions.	Completes only basic testing steps with limited documentation.	Testing procedure is incomplete, unsafe, unauthorized, or poorly executed.	
3	Identification and Validation of Vulnerabilities(20)	Accurately identifies vulnerabilities, manually validates findings, and distinguishes confirmed issues from false positives.	Identifies and validates most important findings with minor gaps.	Identifies basic vulnerabilities but provides limited validation.	Findings are inaccurate, unsupported, or based only on automated tool output.	

4	Risk Analysis and Remediation(20)	Clearly explains the cause, likelihood, impact, severity, and practical remediation for every confirmed vulnerability.	Provides suitable risk analysis and recommendations with minor omissions.	Provides general risk descriptions and basic remediation measures.	Risk ratings are unsupported or recommendations are impractical or unrelated.	
5	Evidence, Report Quality, and Ethical Compliance(20)	Provides clear commands, screenshots, outputs, tables, references, and a professional report while maintaining authorization, confidentiality, and ethical conduct.	Provides sufficient evidence and a well organized report with minor presentation issues.	Provides limited evidence or an adequately organized report.	Evidence is missing, the report is unclear, or ethical and legal requirements are ignored.	
					Total	

Q1 — Web Server Reconnaissance & Vulnerability Analysis

First set your target:

TARGET=192.168.56.101

1. Ping

ping -c 4 \$TARGET

2. IP configuration

ip addr

or:

ifconfig

3. Traceroute

traceroute \$TARGET

If **traceroute** is not installed:

sudo apt install traceroute

4. Netstat

netstat -tulnp

If unavailable:

ss -tulnp

5. WHOIS

For a faculty-provided domain:

whois example.com

For a private lab IP, WHOIS may not provide useful information.

6. Nmap basic scan

`nmap $TARGET`

7. Nmap service/version detection

`nmap -sV $TARGET`

8. Nmap OS/service information

`sudo nmap -sV -O $TARGET`

9. WhatWeb

If the web server is HTTP:

`whatweb http://$TARGET`

If HTTPS:

`whatweb https://$TARGET`

10. HTTP headers using Curl

`curl -I http://$TARGET`

For detailed response:

`curl -i http://$TARGET`

11. Wget

`wget --server-response --spider http://$TARGET`

12. Nikto

`nikto -h http://$TARGET`

13. Gobuster directory discovery

`gobuster dir -u http://$TARGET -w /usr/share/wordlists/dirb/common.txt`

If that wordlist doesn't exist:

`ls /usr/share/wordlists/dirb/`

14. Dirb

dirb http://\$TARGET

15. Nmap HTTP scripts

nmap --script http-enum,http-headers,http-methods -p 80,443 \$TARGET

```
lavanya@kali: ~  
Session Actions Edit View Help  
[~]  
$ TARGET=192.168.56.101  
[~]  
$ ping -c 4 $TARGET  
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:  
--- 192.168.56.101 ping statistics ---  
4 packets transmitted, 0 received, 100% packet loss, time 3062ms  
[~]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 85630sec preferred_lft 85630sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global temporary dynamic  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<global>  
    inet6 fe80::a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<link>  
    ether 08:00:27:91:c4:b2 txqueuelen 1000 (Ethernet)  
    RX packets 27 bytes 5678 (5.5 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 64 bytes 7934 (7.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 236 bytes 14120 (13.7 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 236 bytes 14120 (13.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
[~]  
$ traceroute $TARGET  
traceroute to 192.168.56.101 (192.168.56.101), 30 hops max, 60 byte packets  
 1 10.0.2.2 (10.0.2.2) 0.405 ms 1.510 ms 1.304 ms  
 2 * * *  
 3 * * *  
 4 * * *  
 5 * * *  
 6 * * *  
 7 * * *  
 8 * * *  
 9 * * *  
10 * * *  
11 * * *  
12 * * *  
13 * * *  
14 * * *  
15 * * *  
16 * * *  
17 * * *  
18 * * *  
19 * * *  
20 * * *  
21 * * *  
22 * * *  
23 * * *  
24 * * *  
25 * * *  
26 * * *  
27 * * *  
28 * * *  
29 * * *  
30 * * *  
[~]  
$ netstat -tulnp  
(Not all processes could be identified, non-owned process info  
will not be shown, you would have to be root to see it all.)  
Active Internet connections (only servers)  
Proto Recv-Q Send-Q Local Address Foreign Address State PID/Program name  
[~]  
$ whois example.com  
^CInterrupted by signal 2...
```

```

(lavanya@kali)-[~]
└─$ nmap $TARGET
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:17 +0530
Nmap scan report for 192.168.56.101
Host is up (0.0083s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
5060/tcp  open  sip
5061/tcp  open  sip-tls

Nmap done: 1 IP address (1 host up) scanned in 6.18 seconds
(lavanya@kali)-[~]
└─$ nmap -sv $TARGET
Nmap 7.99 ( https://nmap.org )
Usage: nmap [Scan Type(s)] [Options] {target specification}
TARGET SPECIFICATION:
  Can pass hostnames, IP addresses, networks, etc.
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254
  -iL <inputfilename>: Input from list of hosts/networks
  -iR <num hosts>: Choose random targets
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks
  --excludefile <exclude_file>: Exclude list from file
HOST DISCOVERY:
  -sl: List Scan - simply list targets to scan
  -sn: Ping Scan - disable port scan
  -Pn: Treat all hosts as online -- skip host discovery
  -PS/PA/PU/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes
  -PO[protocol list]: IP Protocol Ping
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers
  --system-dns: Use OS's DNS resolver
  --traceroute: Trace hop path to each host
SCAN TECHNIQUES:
  -sS/sT/sA/sw/sm: TCP SYN/Connect()/ACK/Window/Maimon scans
  -sU: UDP Scan
  -sN/sF/sX: TCP Null, FIN, and Xmas scans
  --scanflags <flags>: Customize TCP scan flags
  -sI <zombie host[:probeport]>: Idle scan
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans
  -sO: IP protocol scan
  -b <FTP relay host>: FTP bounce scan
PORT SPECIFICATION AND SCAN ORDER:
  -p <port ranges>: Only scan specified ports
  Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9
  --exclude-ports <port ranges>: Exclude the specified ports from scanning
  -F: Fast mode - Scan fewer ports than the default scan
  -r: Scan ports sequentially - don't randomize
  --top-ports <number>: Scan <number> most common ports
  --port-ratio <ratio>: Scan ports more common than <ratio>

```

Q2 — Web Application Vulnerability Assessment

Set the target:

TARGET=192.168.56.101

1. Identify services

nmap -sV \$TARGET

2. Identify web technologies

whatweb http://\$TARGET

3. Examine HTTP headers

curl -I http://\$TARGET

4. Examine the webpage

curl -i http://\$TARGET

5. Nikto

nikto -h http://\$TARGET

6. Start Burp Suite

burpsuite

Use the browser configured through Burp and capture the application's requests.

7. Start OWASP ZAP

zaproxy

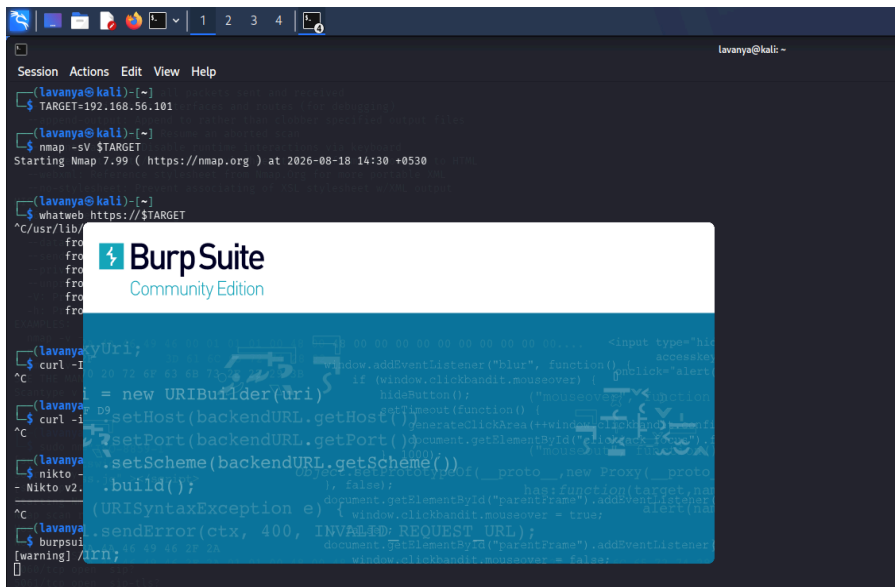
Use the **authorized lab application URL** in ZAP.

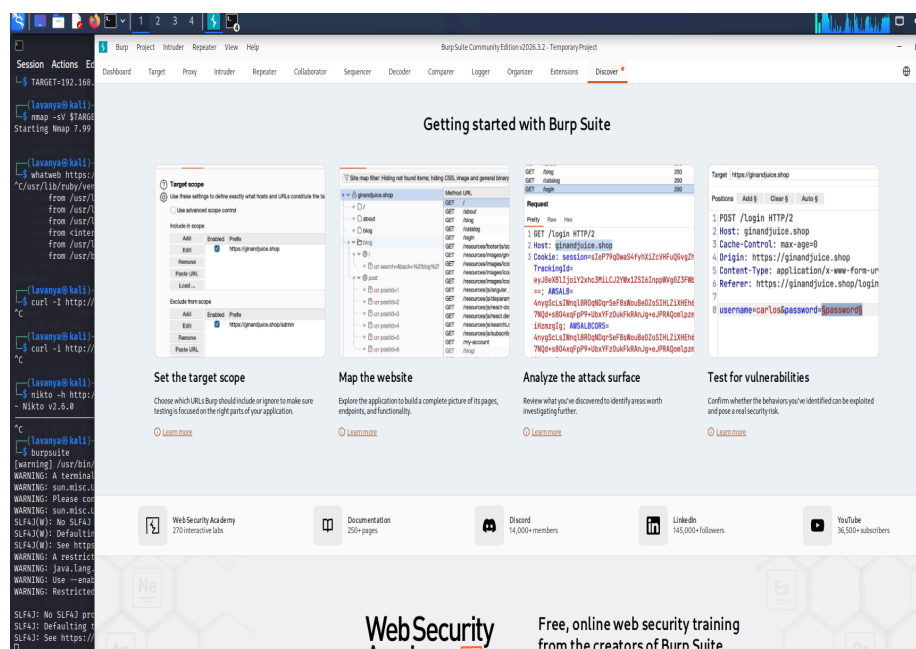
8. Check directories

gobuster dir -u http://\$TARGET -w /usr/share/wordlists/dirb/common.txt

9. Check HTTP methods

nmap --script http-methods -p 80,443 \$TARGET





Q3 — Security Header & HTTPS Configuration

Set target:

TARGET=192.168.56.101

1. HTTP headers

curl -I http://\$TARGET

2. HTTPS headers

curl -k -I https://\$TARGET

3. Check HTTP → HTTPS redirect

curl -I http://\$TARGET

Look for something like:

HTTP/1.1 301

Location: https://...

4. Follow redirects

`curl -IL http://$TARGET`

5. Nmap SSL scan

`nmap -sV -p 443 --script ssl-enum-ciphers $TARGET`

6. Certificate information

`nmap -p 443 --script ssl-cert $TARGET`

7. SSL vulnerability scripts

`nmap -p 443 --script ssl-* $TARGET`

Important headers to look for

Content-Security-Policy

Strict-Transport-Security

X-Frame-Options

X-Content-Type-Options

```
Session Actions Edit View Help
(lavanya@kali)~
$ TARGET=192.168.56.101
(lavanya@kali)~
$ ping -c 4 $TARGET
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
--- 192.168.56.101 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3062ms
(lavanya@kali)~
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85630sec preferred_lft 85630sec
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global temporary dynamic
        valid_lft 86256sec preferred_lft 14256sec
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86256sec preferred_lft 14256sec
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(lavanya@kali)~
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<global>
    inet6 fe80::a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<link>
    inet6 fd17:625c:f037:2:5458:464d:4771:8436 prefixlen 64 scopeid 0<global>
    ether 08:00:27:91:c4:b2 txqueuelen 1000 (Ethernet)
    RX packets 27 bytes 5678 (5.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 64 bytes 7934 (7.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<localhost>
    loop txqueuelen 1000 (local loopback)
    RX packets 236 bytes 14120 (13.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 236 bytes 14120 (13.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Q4 — Broken Access-Control Assessment

This question is mainly performed using **OWASP ZAP**, not by blindly running attack commands.

1. Start ZAP

```
zapproxy
```

2. Identify the target

```
nmap -sV $TARGET
```

3. View application headers

```
curl -I http://$TARGET
```

4. Discover application paths

```
gobuster dir -u http://$TARGET -w /usr/share/wordlists/dirb/common.txt
```

5. In ZAP

Log in using the **student test account provided by your faculty**.

Capture a request such as:

```
/student?id=101
```

or an API request such as:

```
/api/student/101
```

Then compare it with the **other test identifier explicitly provided by your faculty**.

Record:

Request

Response status

Response length

Returned data

User role

Object ID

Do not guess or enumerate real users' IDs.

Authentication vs Authorization

Authentication:

"Who are you?"

Authorization:

"What are you allowed to access?"

For example:

Student login → Authentication successful

Student accessing admin resource → Authorization should fail

```
lavanya@kali: ~  
Session Actions Edit View Help  
[~]  
$ TARGET=192.168.56.101  
[~]  
$ ping -c 4 $TARGET  
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:  
— 192.168.56.101 ping statistics —  
4 packets transmitted, 0 received, 100% packet loss, time 3062ms  
[~]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 85630sec preferred_lft 85630sec  
    inet6 fd17:625c:f037:2:5458:464d:4771:8434/64 scope global temporary dynamic  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<global>  
    inet6 fe80::a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<link>  
    inet6 fd17:625c:f037:2:5458:464d:4771:8434 prefixlen 64 scopeid 0<global>  
    ether 08:00:27:91:c4:b2 txqueuelen 1000 (Ethernet)  
    RX packets 27 bytes 5670 (5.5 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 64 bytes 7934 (7.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 236 bytes 14120 (13.7 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 236 bytes 14120 (13.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Q5 — Automated Scanning & Manual Validation

Set target:

TARGET=192.168.56.101

1. Nmap

nmap -sV \$TARGET

2. Nikto

nikto -h http://\$TARGET

3. Gobuster

gobuster dir -u http://\$TARGET -w /usr/share/wordlists/dirb/common.txt

4. OWASP ZAP

zaproxy

Enter your **authorized lab URL** in ZAP and run the passive/active scan according to your lab instructions.

5. Wapiti

Check installation:

wapiti --version

Scan the authorized lab application:

wapiti -u http://\$TARGET

For a specific lab application path:

wapiti -u http://\$TARGET/app/

```
lavanya@kali: ~  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:91:c4:b2 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0  
        valid_lft 85630sec preferred_lft 85630sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global temporary dynamic  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2/64 scope global dynamic mngtmpaddr noprefixroute  
        valid_lft 86256sec preferred_lft 14256sec  
    inet6 fe80::a00:27ff:fe91:c4b2/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<global>  
    inet6 fe80::a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<link>  
    inet6 fd17:625c:f037:2:a00:27ff:fe91:c4b2 prefixlen 64 scopeid 0<global>  
    ether 08:00:27:91:c4:b2 txqueuelen 1000 (Ethernet)  
    RX packets 27 bytes 5678 (5.5 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 64 bytes 7934 (7.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 236 bytes 14120 (13.7 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 236 bytes 14120 (13.7 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```